

Nombre: Luis Alberto Vargas Gonzalez

Fecha: 22/10/2025

Actividad y unidad: U7 A1 Investigación- Avances y desafíos en la
criptografía de llave pública

Clase: Ciberseguridad.

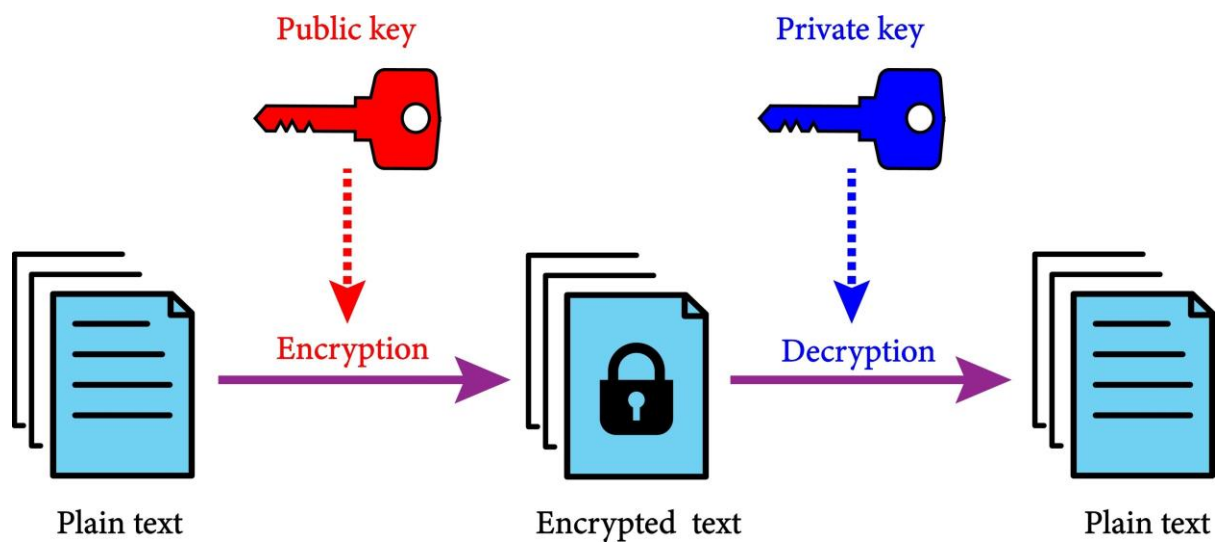
Maestría en Ciberseguridad.

a) Investigación Preliminar: Conceptos Básicos de PKC

La **Criptografía de Clave Pública** (también llamada Criptografía Asimétrica) es un sistema que utiliza un par de claves matemáticamente relacionadas para el cifrado y descifrado:

- **Clave Pública:** Se puede compartir con cualquiera. Se usa para cifrar datos o verificar una firma digital.
- **Clave Privada:** Debe mantenerse en secreto absoluto por su propietario. Se usa para descifrar los datos cifrados con la clave pública o para crear una firma digital.

El principio fundamental es que lo que se cifra con una clave solo se puede descifrar con la otra.



Algoritmos Populares

1. RSA (Rivest-Shamir-Adleman):

- a. **Concepto:** Es el algoritmo de PKC más conocido. Su seguridad se basa en la **dificultad computacional de**

factorizar números enteros grandes que son el producto de dos números primos grandes.

- b. **Uso:** Se utiliza tanto para cifrado (confidencialidad) como para firmas digitales (autenticación).

2. ElGamal:

- a. **Concepto:** Su seguridad se basa en la **difficultad del problema del logaritmo discreto** en un grupo finito.
- b. **Uso:** Generalmente se usa para cifrado y firmas digitales (su variante es el Algoritmo de Firma Digital o DSA).

3. ECC (Elliptic Curve Cryptography - Criptografía de Curva Elíptica):

- a. **Concepto:** Una evolución de la criptografía basada en logaritmo discreto, pero aplicada a puntos en una curva elíptica.
- b. **Principio Clave:** Ofrece el **mismo nivel de seguridad que RSA, pero con claves mucho más pequeñas**. Por ejemplo, una clave ECC de 256 bits se considera equivalente en seguridad a una clave RSA de 3072 bits.
- c. **Uso:** Ideal para entornos con recursos limitados (como dispositivos móviles, tarjetas inteligentes e IoT) debido a su eficiencia (menor cómputo, menor consumo de energía).

Principios y Protocolos Fundamentales

La PKC permite lograr cuatro objetivos de seguridad clave:

1. **Confidencialidad:** Si Alice quiere enviar un mensaje secreto a Bob, cifra el mensaje con la *clave pública* de Bob. Solo Bob puede descifrarlo con su *clave privada*.
2. **Autenticación:** Si Bob quiere probar que es él quien envía un mensaje, usa su *clave privada* para "firmar" el mensaje.

3. **Integridad:** La firma digital también asegura que el mensaje no ha sido alterado desde que fue firmado.
4. **No Repudio:** Bob no puede negar haber enviado el mensaje, ya que solo él posee la clave privada con la que se firmó.

Un protocolo fundamental es el **Intercambio de Claves Diffie-Hellman (DH)**, que permite a dos partes (Alice y Bob) establecer un secreto compartido (una clave simétrica) a través de un canal inseguro, sin haber intercambiado información secreta previamente. ECDH (Elliptic Curve Diffie-Hellman) es la variante moderna que usa curvas elípticas y es fundamental en TLS.

b) Avances Recientes en Criptografía de Clave Pública

Aquí hay tres avances significativos que están redefiniendo el campo:

1. Criptografía Post-Cuántica (PQC)

- a. **Avance:** La investigación y estandarización de algoritmos resistentes a ataques de computadoras cuánticas. El problema es que el **Algoritmo de Shor** (un algoritmo cuántico) puede romper RSA y ECC eficientemente, volviéndolos obsoletos.
- b. **Mejora de Seguridad:** PQC se basa en problemas matemáticos que se creen difíciles de resolver tanto para computadoras clásicas como cuánticas (ej. problemas basados en retículos, códigos, hashes o isogenias). El NIST

(Instituto Nacional de Estándares y Tecnología de EE. UU.) ha finalizado su proceso de selección, eligiendo algoritmos como **CRYSTALS-Kyber** (para intercambio de claves) y **CRYSTALS-Dilithium** (para firmas).

- c. **Eficiencia:** El desafío es que muchas de estas primitivas PQC tienen claves o firmas de mayor tamaño que ECC, lo que presenta retos de eficiencia.

2. Criptografía Homomórfica (HE)

- a. **Avance:** Es una forma de cifrado que permite realizar cálculos directamente sobre los datos cifrados (texto cifrado) sin necesidad de descifrarlos primero.
- b. **Mejora de Seguridad:** Esto es revolucionario para la **privacidad en la nube**. Una empresa puede enviar sus datos cifrados a un proveedor de nube, el proveedor puede procesarlos (ej. realizar análisis estadísticos o entrenar un modelo de IA) y devolver el resultado cifrado. La empresa lo descifra y obtiene el resultado, pero el proveedor de nube *nunca* tuvo acceso a los datos en claro.
- c. **Eficiencia:** Históricamente ha sido muy lenta (computacionalmente costosa), pero los avances recientes (como los esquemas FHE - Fully Homomorphic Encryption) la están haciendo más viable para aplicaciones prácticas.

3. Criptografía Basada en Identidad (IBE - Identity-Based Encryption)

- a. **Avance:** Un tipo de PKC donde la clave pública de un usuario puede ser cualquier cadena de texto que lo identifique de forma única, como su **dirección de correo electrónico** o su número de teléfono.

- b. **Mejora de Eficiencia (en Gestión):** Simplifica enormemente la **gestión de claves**. En un sistema de PKI tradicional, si quieres enviar un correo cifrado a alguien, primero debes *buscar* y *verificar* su certificado de clave pública. Con IBE, simplemente usas nombre@empresa.com como clave pública. Un "Generador de Claves Privadas" (PKG) central emite la clave privada correspondiente al usuario cuando este se autentica.
- c. **Seguridad:** Reduce la complejidad de la infraestructura de clave pública (PKI) y los problemas de distribución de certificados.

c) Aplicaciones Prácticas de la Criptografía de Clave Pública

La PKC es la base de la confianza en el mundo digital.

- **Seguridad de las Comunicaciones (SSL/TLS):** Es la aplicación más visible. Cuando ves el "candado" en tu navegador (HTTPS), estás usando TLS. La PKC (generalmente ECDH) se usa durante el "handshake" inicial para **autenticar el servidor** (a través de su certificado) y para **negociar de forma segura una clave simétrica** (como AES). La comunicación real se cifra con la clave simétrica (más rápida), pero la PKC fue esencial para establecer ese canal seguro.
- **Comercio Electrónico:** Directamente ligado a TLS. Garantiza que tu número de tarjeta de crédito esté cifrado cuando compras en línea y que te estás comunicando con el sitio web legítimo del comerciante y no con un impostor.
- **Autenticación y Firmas Digitales:**

- **Software Seguro:** Los desarrolladores (como Microsoft o Apple) firman digitalmente su software. Tu sistema operativo verifica esta firma (usando la clave pública del desarrollador) antes de instalar, asegurando que el software es legítimo y no ha sido modificado por malware.
- **Documentos Legales:** Las firmas electrónicas avanzadas usan PKC para garantizar la autenticidad e integridad de contratos y documentos oficiales.
- **Correo Electrónico (PGP/GPG):** Permite cifrar correos para privacidad y firmarlos para autenticar al remitente.
- **Seguridad en la Nube:**
 - **Gestión de Acceso:** Las claves SSH, usadas para conectarse de forma segura a servidores (VMs) en la nube, son un ejemplo puro de PKC (autenticación basada en par de claves).
 - **Privacidad de Datos:** Como se mencionó, la Criptografía Homomórfica (HE) permite el procesamiento de datos sensibles en la nube.
- **Seguridad en Dispositivos IoT:**
 - **Desafío:** Los dispositivos IoT (sensores, cámaras, etc.) tienen poca potencia de cómputo y batería.
 - **Solución PKC:** La **Criptografía de Curva Elíptica (ECC)** es la solución aquí. Proporciona seguridad robusta con claves pequeñas y operaciones rápidas, permitiendo que estos dispositivos se autenticuen de forma segura en la red y cifren sus comunicaciones sin agotar sus recursos.

d) Desafíos Actuales y Soluciones

A pesar de su éxito, la PKC enfrenta grandes desafíos:

1. La Amenaza de la Computación Cuántica:

- a. **Desafío:** Es la amenaza existencial. Las computadoras cuánticas, una vez que sean lo suficientemente potentes, podrán ejecutar el **Algoritmo de Shor**, que rompe RSA, ECC y DH fácilmente. Esto significa que todas las comunicaciones HTTPS, firmas de software y criptomonedas actuales serían vulnerables.
- b. **Solución:** La **Criptografía Post-Cuántica (PQC)**. La industria está en un proceso de transición (liderado por NIST) para reemplazar los algoritmos actuales por los nuevos estándares resistentes a la cuántica (como Kyber y Dilithium).

2. Gestión de Claves (Key Management):

- a. **Desafío:** A menudo, el eslabón más débil no es el algoritmo, sino el *proceso humano* de gestionar las claves. ¿Cómo se almacena de forma segura la clave privada? (Si un atacante la roba, puede suplantar al propietario). ¿Cómo se revocan las claves si se ven comprometidas? ¿Cómo se rotan las claves periódicamente?
- b. **Solución:**

- i. **Hardware Security Modules (HSMs):** Dispositivos físicos diseñados para proteger y gestionar claves privadas. La clave *nunca* sale del HSM; las operaciones criptográficas se realizan *dentro* del dispositivo.
- ii. **Infraestructura de Clave Pública (PKI):** Un sistema de Autoridades de Certificación (CAs) que emiten, distribuyen y revocan certificados digitales (que vinculan una identidad a una clave pública).

3. Escalabilidad y Rendimiento:

- a. **Desafío:** Las operaciones de clave pública (ej. una firma RSA) son *mucho* (órdenes de magnitud) más lentas y computacionalmente costosas que las operaciones de clave simétrica (ej. cifrado AES).
- b. **Solución:** El **modelo híbrido** (usado en TLS). No se usa PKC para cifrar todo. Se usa PKC *solo* para el paso inicial de autenticación e intercambio de claves, para establecer de forma segura una clave simétrica (efímera). Luego, esa clave simétrica (rápida) se usa para cifrar el resto de la comunicación.

4. Ataques de Canal Lateral (Side-Channel Attacks):

- a. **Desafío:** Ataques que no se dirigen a la matemática del algoritmo, sino a su *implementación física*. Un atacante puede medir el consumo de energía, el tiempo de procesamiento o las emisiones electromagnéticas del dispositivo mientras realiza una operación criptográfica para inferir la clave privada.
- b. **Solución:** Técnicas de "programación en tiempo constante" (asegurar que las operaciones tarden lo mismo

independientemente de los datos) y contramedidas a nivel de hardware.

e) Estudio de Caso: TLS 1.3 (Transport Layer Security)

Sistema: TLS 1.3, el protocolo estándar que asegura las comunicaciones web (HTTPS), correo electrónico (STARTTLS) y muchas otras conexiones.

Uso de Criptografía de Clave Pública: TLS 1.3 utiliza PKC de forma intensiva, pero optimizada, principalmente para dos cosas: **autenticación y acuerdo de claves.**

1. **Autenticación del Servidor:** Cuando te conectas a `uag.mx`, el servidor de la UAG presenta un **Certificado Digital X.509**. Este certificado contiene la clave pública del servidor y está firmado digitalmente por una Autoridad de Certificación (CA) confiable (ej. Let's Encrypt, DigiCert). Tu navegador usa la clave pública de la CA (que ya tiene preinstalada) para verificar la firma del certificado. Esto prueba que el servidor es quien dice ser.
2. **Acuerdo de Claves:** Una vez autenticado el servidor, el cliente y el servidor necesitan una clave simétrica para cifrar la sesión. En lugar de que el cliente genere una y la cifre con la clave pública del servidor (como se hacía en versiones antiguas de TLS), TLS 1.3 usa **ECDH Efímero (Elliptic Curve Diffie-Hellman Ephemeral)**.
 - a. "Efímero" significa que ambos lados generan un par de claves ECDH *temporal* solo para esta sesión.

- b. Intercambian sus claves públicas temporales (firmadas con sus claves privadas de largo plazo para probar propiedad) y realizan el cálculo DH para llegar *independientemente* al mismo secreto compartido (la clave de sesión).

Ventajas y Desafíos:

- **Ventaja (Seguridad):** El uso de ECDH *Efímero* proporciona **Forward Secrecy (Secreto Perfecto Hacia Adelante)**. Si un atacante roba la clave privada de largo plazo del servidor *en el futuro*, no podrá descifrar las comunicaciones *pasadas* que interceptó, porque esas sesiones estaban protegidas por claves temporales que ya fueron descartadas.
- **Ventaja (Eficiencia):** TLS 1.3 es mucho más rápido que sus predecesores. Redujo el "handshake" (negociación inicial) de dos viajes de ida y vuelta a solo uno (1-RTT), haciendo que las conexiones seguras se establezcan más rápido.
- **Desafío:** La migración. Asegurar que todos los servidores, clientes, firewalls y *middleboxes* (equipos de seguridad de red) se actualicen para soportar TLS 1.3 fue un desafío de implementación masivo.

Lecciones Aprendidas: La evolución de TLS nos enseña que el **modelo híbrido** (PKC para acuerdo de claves + Criptografía Simétrica para datos) es el diseño más robusto. También demuestra la importancia de la **agilidad criptográfica** (poder cambiar a algoritmos más nuevos y seguros como ECC) y la necesidad crítica del **Forward Secrecy** como estándar de facto.

¡Claro que sí! Esta es una tarea fundamental en ciberseguridad. La Criptografía de Clave Pública (PKC) es uno de los pilares de la seguridad moderna.

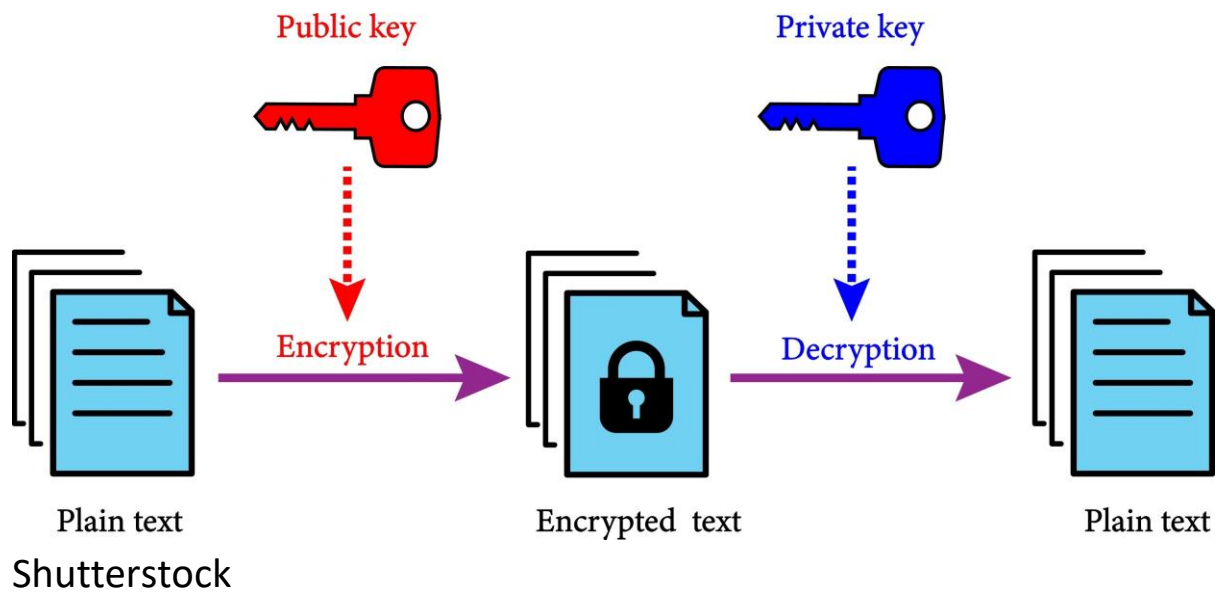
Aquí tienes una investigación estructurada que sigue paso a paso los puntos que solicitaste, lista para que la uses como base sólida para tu informe.

a) Investigación Preliminar: Conceptos Básicos de PKC

La **Criptografía de Clave Pública** (también llamada Criptografía Asimétrica) es un sistema que utiliza un par de claves matemáticamente relacionadas para el cifrado y descifrado:

- **Clave Pública:** Se puede compartir con cualquiera. Se usa para cifrar datos o verificar una firma digital.
- **Clave Privada:** Debe mantenerse en secreto absoluto por su propietario. Se usa para descifrar los datos cifrados con la clave pública o para crear una firma digital.

El principio fundamental es que lo que se cifra con una clave solo se puede descifrar con la otra.



Algoritmos Populares

1. RSA (Rivest-Shamir-Adleman):

- a. **Concepto:** Es el algoritmo de PKC más conocido. Su seguridad se basa en la **dificultad computacional de factorizar números enteros grandes** que son el producto de dos números primos grandes.
- b. **Uso:** Se utiliza tanto para cifrado (confidencialidad) como para firmas digitales (autenticación).

2. ElGamal:

- a. **Concepto:** Su seguridad se basa en la **dificultad del problema del logaritmo discreto** en un grupo finito.
- b. **Uso:** Generalmente se usa para cifrado y firmas digitales (su variante es el Algoritmo de Firma Digital o DSA).

3. ECC (Elliptic Curve Cryptography - Criptografía de Curva Elíptica):

- a. **Concepto:** Una evolución de la criptografía basada en logaritmo discreto, pero aplicada a puntos en una curva elíptica.

- b. **Principio Clave:** Ofrece el **mismo nivel de seguridad que RSA pero con claves mucho más pequeñas**. Por ejemplo, una clave ECC de 256 bits se considera equivalente en seguridad a una clave RSA de 3072 bits.
- c. **Uso:** Ideal para entornos con recursos limitados (como dispositivos móviles, tarjetas inteligentes e IoT) debido a su eficiencia (menor cómputo, menor consumo de energía).

Principios y Protocolos Fundamentales

La PKC permite lograr cuatro objetivos de seguridad clave:

1. **Confidencialidad:** Si Alice quiere enviar un mensaje secreto a Bob, cifra el mensaje con la *clave pública* de Bob. Solo Bob puede descifrarlo con su *clave privada*.
2. **Autenticación:** Si Bob quiere probar que es él quien envía un mensaje, usa su *clave privada* para "firmar" el mensaje.
3. **Integridad:** La firma digital también asegura que el mensaje no ha sido alterado desde que fue firmado.
4. **No Repudio:** Bob no puede negar haber enviado el mensaje, ya que solo él posee la clave privada con la que se firmó.

Un protocolo fundamental es el **Intercambio de Claves Diffie-Hellman (DH)**, que permite a dos partes (Alice y Bob) establecer un secreto compartido (una clave simétrica) a través de un canal inseguro, sin haber intercambiado información secreta previamente. ECDH (Elliptic Curve Diffie-Hellman) es la variante moderna que usa curvas elípticas y es fundamental en TLS.

b) Avances Recientes en Criptografía de Clave Pública

Aquí hay tres avances significativos que están redefiniendo el campo:

1. Criptografía Post-Cuántica (PQC)

- a. **Avance:** La investigación y estandarización de algoritmos resistentes a ataques de computadoras cuánticas. El problema es que el **Algoritmo de Shor** (un algoritmo cuántico) puede romper RSA y ECC eficientemente, volviéndolos obsoletos.
- b. **Mejora de Seguridad:** PQC se basa en problemas matemáticos que se creen difíciles de resolver tanto para computadoras clásicas como cuánticas (ej. problemas basados en retículos, códigos, hashes o isogenias). El NIST (Instituto Nacional de Estándares y Tecnología de EE. UU.) ha finalizado su proceso de selección, eligiendo algoritmos como **CRYSTALS-Kyber** (para intercambio de claves) y **CRYSTALS-Dilithium** (para firmas).
- c. **Eficiencia:** El desafío es que muchas de estas primitivas PQC tienen claves o firmas de mayor tamaño que ECC, lo que presenta retos de eficiencia.

2. Criptografía Homomórfica (HE)

- a. **Avance:** Es una forma de cifrado que permite realizar cálculos directamente sobre los datos cifrados (texto cifrado) sin necesidad de descifrarlos primero.
- b. **Mejora de Seguridad:** Esto es revolucionario para la **privacidad en la nube**. Una empresa puede enviar sus datos cifrados a un proveedor de nube, el proveedor puede procesarlos (ej. realizar análisis estadísticos o entrenar un modelo de IA) y devolver el resultado cifrado. La empresa lo descifra y obtiene el resultado, pero el

proveedor de nube *nunca* tuvo acceso a los datos en claro.

- c. **Eficiencia:** Históricamente ha sido muy lenta (computacionalmente costosa), pero los avances recientes (como los esquemas FHE - Fully Homomorphic Encryption) la están haciendo más viable para aplicaciones prácticas.

3. Criptografía Basada en Identidad (IBE - Identity-Based Encryption)

- a. **Avance:** Un tipo de PKC donde la clave pública de un usuario puede ser cualquier cadena de texto que lo identifique de forma única, como su **dirección de correo electrónico** o su número de teléfono.
- b. **Mejora de Eficiencia (en Gestión):** Simplifica enormemente la **gestión de claves**. En un sistema de PKI tradicional, si quieres enviar un correo cifrado a alguien, primero debes *buscar* y *verificar* su certificado de clave pública. Con IBE, simplemente usas nombre@empresa.com como clave pública. Un "Generador de Claves Privadas" (PKG) central emite la clave privada correspondiente al usuario cuando este se autentica.
- c. **Seguridad:** Reduce la complejidad de la infraestructura de clave pública (PKI) y los problemas de distribución de certificados.

c) Aplicaciones Prácticas de la Criptografía de Clave Pública

La PKC es la base de la confianza en el mundo digital.

- **Seguridad de las Comunicaciones (SSL/TLS):**  Es la aplicación más visible. Cuando ves el "candado" en tu navegador (HTTPS), estás usando TLS. La PKC (generalmente ECDH) se usa durante el "handshake" inicial para **autenticar el servidor** (a través de su certificado) y para **negociar de forma segura una clave simétrica** (como AES). La comunicación real se cifra con la clave simétrica (más rápida), pero la PKC fue esencial para establecer ese canal seguro.
- **Comercio Electrónico:** Directamente ligado a TLS. Garantiza que tu número de tarjeta de crédito esté cifrado cuando compras en línea y que te estás comunicando con el sitio web legítimo del comerciante y no con un impostor.
- **Autenticación y Firmas Digitales:**
 - **Software Seguro:** Los desarrolladores (como Microsoft o Apple) firman digitalmente su software. Tu sistema operativo verifica esta firma (usando la clave pública del desarrollador) antes de instalar, asegurando que el software es legítimo y no ha sido modificado por malware.
 - **Documentos Legales:** Las firmas electrónicas avanzadas usan PKC para garantizar la autenticidad e integridad de contratos y documentos oficiales.
 - **Correo Electrónico (PGP/GPG):** Permite cifrar correos para privacidad y firmarlos para autenticar al remitente.
- **Seguridad en la Nube:**
 - **Gestión de Acceso:** Las claves SSH, usadas para conectarse de forma segura a servidores (VMs) en la nube, son un ejemplo puro de PKC (autenticación basada en par de claves).

- **Privacidad de Datos:** Como se mencionó, la Criptografía Homomórfica (HE) permite el procesamiento de datos sensibles en la nube.
- **Seguridad en Dispositivos IoT:** 
 - **Desafío:** Los dispositivos IoT (sensores, cámaras, etc.) tienen poca potencia de cómputo y batería.
 - **Solución PKC:** La **Criptografía de Curva Elíptica (ECC)** es la solución aquí. Proporciona seguridad robusta con claves pequeñas y operaciones rápidas, permitiendo que estos dispositivos se autenticuen de forma segura en la red y cifren sus comunicaciones sin agotar sus recursos.

d) Desafíos Actuales y Soluciones

A pesar de su éxito, la PKC enfrenta grandes desafíos:

1. La Amenaza de la Computación Cuántica:

- a. **Desafío:** Es la amenaza existencial. Las computadoras cuánticas, una vez que sean lo suficientemente potentes, podrán ejecutar el **Algoritmo de Shor**, que rompe RSA, ECC y DH fácilmente. Esto significa que todas las comunicaciones HTTPS, firmas de software y criptomonedas actuales serían vulnerables.
- b. **Solución:** La **Criptografía Post-Cuántica (PQC)**. La industria está en un proceso de transición (liderado por NIST) para reemplazar los algoritmos actuales por los nuevos estándares resistentes a la cuántica (como Kyber y Dilithium).

2. Gestión de Claves (Key Management):

- a. **Desafío:** A menudo, el eslabón más débil no es el algoritmo, sino el *proceso humano* de gestionar las claves. ¿Cómo se almacena de forma segura la clave privada? (Si un atacante la roba, puede suplantar al propietario). ¿Cómo se revocan las claves si se ven comprometidas? ¿Cómo se rotan las claves periódicamente?

b. Solución:

- i. **Hardware Security Modules (HSMs):** Dispositivos físicos diseñados para proteger y gestionar claves privadas. La clave *nunca* sale del HSM; las operaciones criptográficas se realizan *dentro* del dispositivo.
- ii. **Infraestructura de Clave Pública (PKI):** Un sistema de Autoridades de Certificación (CAs) que emiten, distribuyen y revocan certificados digitales (que vinculan una identidad a una clave pública).

3. Escalabilidad y Rendimiento:

- a. **Desafío:** Las operaciones de clave pública (ej. una firma RSA) son *mucho* (órdenes de magnitud) más lentas y computacionalmente costosas que las operaciones de clave simétrica (ej. cifrado AES).
- b. **Solución:** El **modelo híbrido** (usado en TLS). No se usa PKC para cifrar todo. Se usa PKC *solo* para el paso inicial de autenticación e intercambio de claves, para establecer de forma segura una clave simétrica (efímera). Luego, esa clave simétrica (rápida) se usa para cifrar el resto de la comunicación.

4. Ataques de Canal Lateral (Side-Channel Attacks):

- a. **Desafío:** Ataques que no se dirigen a la matemática del algoritmo, sino a su *implementación física*. Un atacante

puede medir el consumo de energía, el tiempo de procesamiento o las emisiones electromagnéticas del dispositivo mientras realiza una operación criptográfica para inferir la clave privada.

- b. **Solución:** Técnicas de "programación en tiempo constante" (asegurar que las operaciones tarden lo mismo independientemente de los datos) y contramedidas a nivel de hardware.

e) Estudio de Caso: TLS 1.3 (Transport Layer Security)

Sistema: TLS 1.3, el protocolo estándar que asegura las comunicaciones web (HTTPS), correo electrónico (STARTTLS) y muchas otras conexiones.

Uso de Criptografía de Clave Pública: TLS 1.3 utiliza PKC de forma intensiva, pero optimizada, principalmente para dos cosas: **autenticación y acuerdo de claves.**

1. **Autenticación del Servidor:** Cuando te conectas a `uag.mx`, el servidor de la UAG presenta un **Certificado Digital X.509**. Este certificado contiene la clave pública del servidor y está firmado digitalmente por una Autoridad de Certificación (CA) confiable (ej. Let's Encrypt, DigiCert). Tu navegador usa la clave pública de la CA (que ya tiene preinstalada) para verificar la firma del certificado. Esto prueba que el servidor es quien dice ser.
2. **Acuerdo de Claves:** Una vez autenticado el servidor, el cliente y el servidor necesitan una clave simétrica para cifrar la sesión. En lugar de que el cliente genere una y la cifre con la clave pública del servidor (como se hacía en versiones antiguas de

TLS), TLS 1.3 usa **ECDH Efímero (Elliptic Curve Diffie-Hellman Ephemeral)**.

- a. "Efímero" significa que ambos lados generan un par de claves ECDH *temporal* solo para esta sesión.
- b. Intercambian sus claves públicas temporales (firmadas con sus claves privadas de largo plazo para probar propiedad) y realizan el cálculo DH para llegar *independientemente* al mismo secreto compartido (la clave de sesión).

Ventajas y Desafíos:

- **Ventaja (Seguridad):** El uso de ECDH *Efímero* proporciona **Forward Secrecy (Secreto Perfecto Hacia Adelante)**. Si un atacante roba la clave privada de largo plazo del servidor *en el futuro*, no podrá descifrar las comunicaciones *pasadas* que interceptó, porque esas sesiones estaban protegidas por claves temporales que ya fueron descartadas.
- **Ventaja (Eficiencia):** TLS 1.3 es mucho más rápido que sus predecesores. Redujo el "handshake" (negociación inicial) de dos viajes de ida y vuelta a solo uno (1-RTT), haciendo que las conexiones seguras se establezcan más rápido.
- **Desafío:** La migración. Asegurar que todos los servidores, clientes, firewalls y *middleboxes* (equipos de seguridad de red) se actualicen para soportar TLS 1.3 fue un desafío de implementación masivo.

Lecciones Aprendidas: La evolución de TLS nos enseña que el **modelo híbrido** (PKC para acuerdo de claves + Criptografía Simétrica para datos) es el diseño más robusto. También demuestra la importancia de la **agilidad criptográfica** (poder cambiar a algoritmos

más nuevos y seguros como ECC) y la necesidad crítica del **Forward Secrecy** como estándar de facto.

f) Conclusiones y Recomendaciones

Conclusiones

La Criptografía de Clave Pública ha sido la revolución que permitió la confianza en sistemas abiertos como Internet. Pasó de ser un concepto teórico (Diffie-Hellman) a una herramienta práctica (RSA) y, finalmente, a una tecnología optimizada (ECC) que asegura desde transacciones bancarias hasta dispositivos IoT.

Actualmente, el campo se encuentra en un punto de inflexión crítico. Si bien la PKC resolvió los problemas de intercambio de claves y autenticación del siglo XX, enfrenta dos grandes desafíos: la **gestión**

de la complejidad (PKI, gestión de claves) y la **amenaza cuántica** (obsolescencia algorítmica).

Los avances como la Criptografía Homomórfica y Post-Cuántica muestran una clara dirección futura: hacia una criptografía que no solo protege datos en tránsito, sino también datos en uso (HE) y que es segura contra futuros paradigmas de computación (PQC).

Recomendaciones

1. **Priorizar la Agilidad Criptográfica:** Las organizaciones ya no pueden implementar un algoritmo (ej. RSA-2048) y olvidarse de él por 20 años. Se debe adoptar una postura de "agilidad criptográfica", donde los sistemas estén diseñados para **actualizar y reemplazar algoritmos criptográficos** fácilmente. Esto es vital para la migración a PQC.
2. **Iniciar la Transición a PQC (Post-Quantum Cryptography):** Aunque las computadoras cuánticas a gran escala aún no existen, las organizaciones (especialmente las que manejan datos sensibles con larga vida útil) deben **comenzar a planificar ya**. El primer paso es **inventariar** todo el uso de criptografía de clave pública en sus sistemas y prepararse para los estándares PQC (ej. los seleccionados por NIST).
3. **Invertir en Gestión de Claves:** Reforzar las prácticas de gestión de claves. Esto incluye la adopción generalizada de **HSMs** para claves privadas críticas (como las de las CAs internas o servidores TLS) y la automatización de la rotación y revocación de certificados para reducir el error humano.
4. **Adoptar ECC sobre RSA (Mientras tanto):** Para todos los sistemas nuevos que no están listos para PQC, se debe **preferir ECC sobre RSA**. Ofrece una seguridad más robusta con un

rendimiento mucho mayor y menor sobrecarga, lo cual es esencial en el panorama actual de IoT y movilidad.

Referencias Bibliográficas.

1. When to use RSA and ElGamal Asymmetric Encryption. Cryptography Stack Exchange. <https://crypto.stackexchange.com/questions/1677/when-to-use-rsa-and-when-elgamal-asymmetric-encryption>. Published 17 de enero de 2012.
2. Christian AA. Diffie-Hellman, RSA, DSA, ECC and ECDSA – Asymmetric Key Algorithms. SSL2BUY. <https://www.ssl2buy.com/wiki/diffie-hellman-rsa-dsa-ecc-and-ecdsa-asymmetric-key-algorithms>. Published 4 de diciembre de 2024.
3. Krantz T, Jonker A. Cifrado de clave pública. IBM. <https://www.ibm.com/mx-es/think/topics/public-key-encryption>. Published agosto 18, 2025.
4. Chamola S. Overcoming common challenges in PKI Management | Encryption Consulting. *Encryption Consulting*. junio 2025. <https://www.encryptionconsulting.com/es/Superar-los-desaf%C3%ADos-comunes-en-la-gesti%C3%B3n-de-PKI/>.
5. A.2. Cifrado de llave pública | Guía de seguridad | Red Hat Enterprise Linux | 6 | Red Hat Documentation. https://docs.redhat.com/es/documentation/red_hat_enterprise_linux/6/html/security_guide/apas02.

6. Mefp. 2.6.- Principales aplicaciones de la criptografía. | DAM_PSP_07.
https://sarreplec.caib.es/pluginfile.php/10484/mod_resource/content/2/PSP07_Contenidos_Web/26_principales_aplicaciones_de_la_criptografa.html.
7. López G. A, Díaz A. A. *La Criptografía De Clave Pública Y Su Aplicación a Las Tecnologías De La Información*. Telefónica I+D; 2000.
https://www.profesores.frc.utn.edu.ar/sistemas/ingsanchez/Redes/Archivos/Criptografia_de_clave_publica.pdf. Accedido octubre 22, 2025.